CONFIDENTIAL

Vulnerability Assessment & Penetration Testing (VAPT) Report

External Reconnaissance & Attack-Surface Assessment of networkwalks.com

Target	networkwalks.com (192.232.216.135)
Engagement	Networkwalks Week 2, Project Module 1 (W2-PM1): Footprinting & Reconnaissance with multiple Kali tools
Report reference	NW-VAPT-W2-001
Assessment window	5 - 9 November 2026 (timestamps as logged by the Kali VM, UTC-05:00)
Report date	10 November 2026
Version / status	1.0 - Final
Prepared by	Kitsana Thuekoh, Penetration Tester / Offensive Security Researcher
Classification	Confidential - for the engagement owner and authorised reviewers only

Authorisation and ethics statement

All testing was limited to the designated lab target named in the Networkwalks W2-PM1 course brief, using non-intrusive reconnaissance tools. No exploitation, credential attack, denial-of-service or intrusive scanning was performed. Testing outside a written scope is illegal; the methods in this report must not be reused against systems without the owner's written permission.

Document Control

Version	Date	Author	Change
1.0	10 Nov 2026	Kitsana Thuekoh	Initial release - reconnaissance phase findings and recommendations

Distribution and handling

This document contains information about the internet-facing infrastructure of the target and the tester's lab environment. It should be shared only with the engagement owner and personnel responsible for remediation, and stored securely. Raw tool output and screenshots are reproduced as evidence in Section 5 and the appendices.

Table of Contents

1. Executive Summary

This report presents the results of an external reconnaissance and attack-surface assessment of **networkwalks.com**, performed as the information-gathering phase of a Vulnerability Assessment and Penetration Testing (VAPT) engagement. Six reconnaissance tools (`whois`, `whatweb`, `nslookup`, `curl`, `wafw00f` and `dnsrecon`) were run from a Kali Linux virtual machine between 5 and 9 November 2026, supported by a Zenmap host-discovery scan of the tester's own lab network.

The purpose was to build the profile an adversary would assemble before any attack (ownership, hosting, stack, DNS/e-mail setup and defences) and to identify what the organisation leaks. **No exploitation, credential testing or intrusive scanning was performed**, so the results describe exposure and hardening gaps rather than confirmed exploitable vulnerabilities.

> **Overall assessment: LOW exposure at reconnaissance level**
>
> The target is a WordPress site on shared HostGator / cPanel infrastructure, protected by a ModSecurity (SpiderLabs) Web Application Firewall, enforcing HTTPS (HTTP/2) and behind a locked, privacy-protected domain registration.
>
> Nine observations were recorded: **0 Critical, 0 High, 0 Medium, 4 Low and 5 Informational**. Most reduce attacker effort in later phases (version disclosure, missing hardening headers, shared hosting) rather than being directly exploitable.
>
> The true risk of the disclosed software versions (WordPress 7.1.4, WP Download Manager 3.3.75, BIND 9.16.23-RH) is **not yet known**: it requires advisory correlation and validation in an authorised vulnerability-assessment phase.

Findings by severity

Severity	Count	Findings
Critical / High / Medium	0	None identified at reconnaissance level
Low	4	NW-01 Security headers; NW-02 E-mail authentication; NW-03 Version disclosure (web); NW-04 BIND version disclosure
Informational	5	NW-05 DNSSEC; NW-06 REST API; NW-07 NS inconsistency; NW-08 Shared hosting; NW-09 Public e-mail

Priority recommendations

1. **Harden HTTP responses** (NW-01): HSTS, CSP, X-Content-Type-Options, frame protection, SameSite cookies.
2. **Close the e-mail spoofing gap** (NW-02): verify and enforce DMARC, enable DKIM, move SPF to hard-fail.
3. **Patch and reduce disclosure** (NW-03): update WordPress and plugins, remove generator tags, and check the disclosed versions against advisories.
4. **Reconcile DNS** (NW-04, NW-05, NW-07): align the name-server set, raise the BIND banner with the provider and plan DNSSEC.
5. **Proceed to the authorised next phase**: port/service discovery, TLS review, WordPress enumeration and vulnerability validation (Section 8).

2. Scope and Methodology

2.1 Scope

Item	Detail	Status
Primary target	networkwalks.com / 192.232.216.135 (web and mail host)	In scope
Name servers	ns6135.hostgator.com (50.87.144.87); ns6136.hostgator.com (192.232.216.131)	In scope - DNS queries only
Registration data	WHOIS records at registry and registrar level	In scope - passive
Tester network	192.168.10.0/24 lab LAN (Kali VM 192.168.10.23, gateway 192.168.10.1)	Own environment - host discovery only
Out of scope	Port scanning, vulnerability scanning, authentication testing, exploitation, social engineering, third-party systems	Not performed

2.2 Approach and standards

The work follows the **Intelligence Gathering** stage of the Penetration Testing Execution Standard (PTES), maps to **OWASP Web Security Testing Guide** information-gathering tests (WSTG-INFO) and to **NIST SP 800-115** discovery techniques. Tool behaviour is mapped to **MITRE ATT&CK Reconnaissance (TA0043)** so defenders can relate each activity to detection opportunities.

Tool	Purpose	Interaction	ATT&CK	Output / evidence
whois	Domain ownership, registrar, dates, name servers	Passive (registry/registrar query)	T1596.002	Task1_whois.txt; Figures 2-3
nslookup	Resolve name to IP via DNS	Passive (DNS)	T1590.002	nslookup.txt; Figure 4
dnsrecon	Enumerate NS, MX, A, TXT/SPF, SRV, BIND version	Active-low (queries authoritative servers)	T1590.002	dnsrecon.txt; Figure 5
whatweb	Fingerprint web server, CMS, plugins	Active-low (direct HTTP requests)	T1592.002	whatweb.txt; Figure 6
curl -I	Read HTTP response headers	Active-low (one HEAD request)	T1592.002	curl.txt; Figure 7
wafw00f	Detect Web Application Firewall	Active-low (2 requests)	T1595	wafw00f.txt; Figure 8
Zenmap / nmap -sn	Ping sweep of tester's own LAN	Active, own network	n/a	Figures 9-10

Note on interaction levels: course material describes this phase as undetectable. In practice, whois and DNS lookups are passive from the target's perspective, but whatweb, curl, wafw00f and dnsrecon send requests that appear in web-server or DNS logs and may be flagged by a WAF. They are low-volume and non-intrusive.

2.3 Severity rating

Rating	Definition
Critical	Directly exploitable weakness giving full compromise of systems or data with little or no prerequisite.
High	Exploitable weakness likely to lead to significant compromise or data exposure.
Medium	Weakness requiring specific conditions or chaining, with moderate impact.
Low	Hardening gap or information disclosure that helps an adversary but is not directly exploitable.
Informational	Observation with no direct security impact, or one needing verification in a later phase.

2.4 Limitations

- Single vantage point (a Kali VM behind a NAT lab network); DNS answers came through the local gateway resolver (192.168.10.1), so geo-dependent or cached answers may differ.
- curl inspected one HEAD request to the home page; other paths, authenticated areas and sub-domains were not assessed.
- Version strings come from banners and meta tags and can be spoofed, truncated or back-ported; WAF detection is heuristic.
- No vulnerability scanner, port scan or exploit was run against the target, so no finding is a confirmed vulnerability.
- Tool output carries Kali VM timestamps (UTC-05:00), which differ from local South African time.

3. Target Profile and Attack Surface

Attribute	Observed value
Domain / registrar	NETWORKWALKS.COM; GoDaddy.com, LLC (IANA ID 146); registry domain ID 2452319255_DOMAIN_COM-VRSN
Registration dates	Created 2019-11-06; last updated 2025-11-12; registry expiry 2027-11-06
Registrant privacy	Redacted via Domains By Proxy, LLC (Tempe, Arizona, US); contact by registrar web form
Domain locks	clientTransferProhibited, clientUpdateProhibited, clientRenewProhibited, clientDeleteProhibited
Name servers	NS6135.HOSTGATOR.COM, NS6136.HOSTGATOR.COM (registry); plus NS29/NS30.DOMAINCONTROL.COM (registrar view)
Web/mail IP	192.232.216.135 (A record; MX mail.networkwalks.com resolves to the same address); geolocated to United States
Web server / CMS	Apache; WordPress 7.1.4; WordPress Download Manager 3.3.75; jQuery 3.7.1; Google Tag Manager; title 'Networkwalks Academy'
Protocols	HTTP -> HTTPS (301, x-redirect-by); HTTP/2 200 on HTTPS
Defensive controls	ModSecurity (SpiderLabs) WAF; Secure + HttpOnly cookie; registrar locks; WHOIS privacy
DNS software	BIND 9.16.23-RH on both name servers; DNSSEC unsigned
E-mail	SPF `v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all`; Google site verification TXT; 8 cPanel autodiscover SRV records

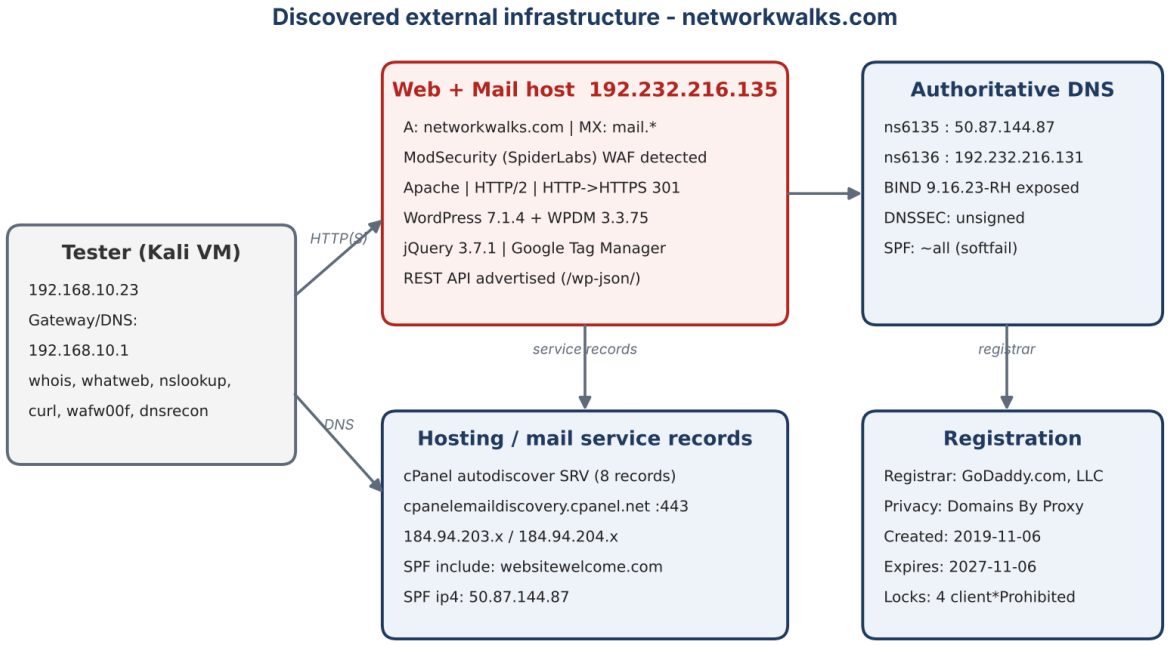


Figure 1: Discovered external infrastructure of networkwalks.com (derived from tool output)

4. Findings Register

The register lists every observation in order of severity. Detailed descriptions, evidence and remediation follow in Section 6.

ID	Finding	Severity	Affected asset
NW-01	Missing HTTP security response headers and weak cookie/referrer settings	**Low**	https://networkwalks.com (192.232.216.135)
NW-02	E-mail authentication posture: permissive SPF, DMARC and DKIM unverified	**Low**	networkwalks.com DNS (TXT) and mail.networkwalks.com (192.232.216.135)
NW-03	Software and version disclosure on the web tier	**Low**	https://networkwalks.com (192.232.216.135)
NW-04	DNS server software version disclosure (BIND 9.16.23-RH)	**Low**	ns6135.hostgator.com (50.87.144.87), ns6136.hostgator.com (192.232.216.131)
NW-05	DNSSEC not deployed	**Informational**	networkwalks.com (registry and registrar record; dnsrecon)
NW-06	WordPress REST API advertised in HTTP Link header	**Informational**	https://networkwalks.com/wp-json/
NW-07	Name-server inconsistency between registry and registrar records	**Informational**	networkwalks.com delegation
NW-08	Consolidated shared-hosting footprint (web, mail and cPanel services)	**Informational**	192.232.216.135; 50.87.144.87; 184.94.203.x / 184.94.204.x
NW-09	Public contact address exposed on the website	**Informational**	https://networkwalks.com

Positive observations

- A **ModSecurity (SpiderLabs) WAF** is in front of the site, which blunts naive automated attacks.
- **HTTPS is enforced** with a 301 redirect and HTTP/2 is in use.
- The application cookie is set with **Secure and HttpOnly** flags.
- The domain has **all four registrar locks** and **WHOIS privacy** enabled, reducing hijack and social-engineering risk.
- The registration runs to **6 November 2027**, about twelve months from the report date. Enable auto-renewal and calendar a review ahead of expiry.

5. Technical Evidence and Analysis

Each subsection gives the command, the key observations from the saved output, the supporting screenshot and an assessment from an attacker's perspective.

5.1 Domain registration (whois)

```
$ whois networkwalks.com
```

- Registrar GoDaddy.com, LLC; created 2019-11-06; expires 2027-11-06; name servers `NS6135.HOSTGATOR.COM` and `NS6136.HOSTGATOR.COM`; DNSSEC unsigned.
- Registrant details are redacted behind Domains By Proxy, LLC; the registrar record also lists `NS29.DOMAINCONTROL.COM` and `NS30.DOMAINCONTROL.COM` (see NW-07).
- The name servers immediately identify HostGator as the DNS and probable hosting provider.

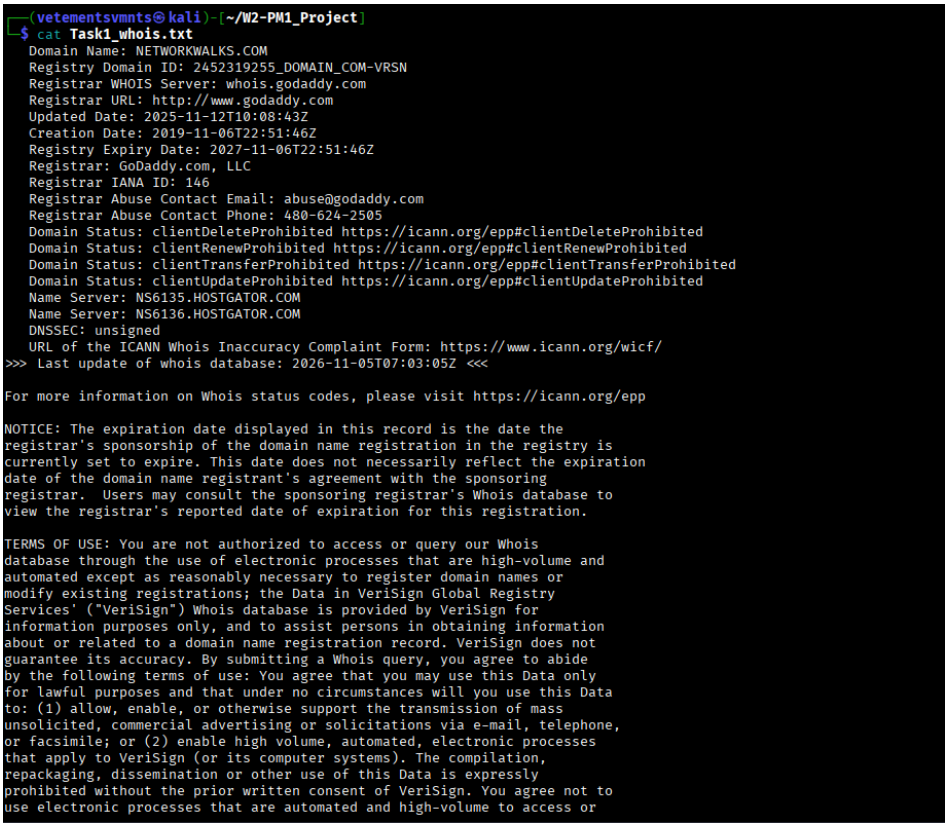


Figure 2: Registry-level WHOIS record (Task1_whois.txt)

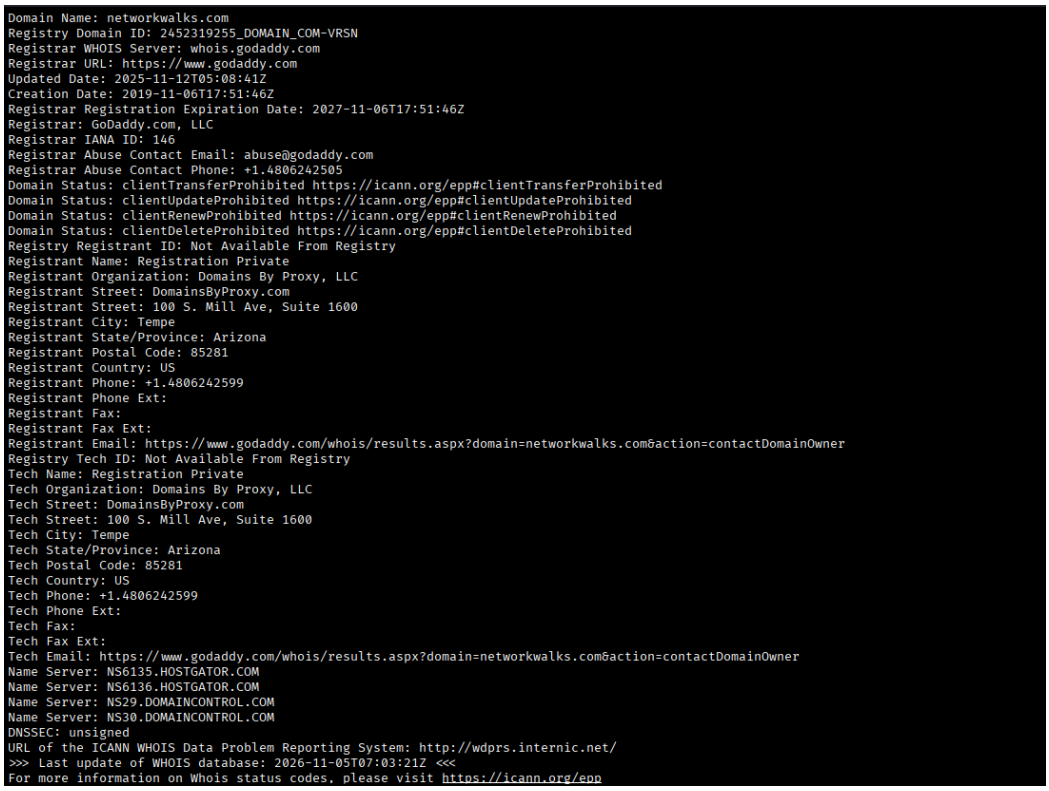


Figure 3: Registrar-level WHOIS record showing privacy proxy and four name servers

Assessment: the registration is well protected. The data an adversary gains is the hosting provider, domain age and expiry, and the registrar abuse contact, which support infrastructure mapping and lookalike-domain planning.

5.2 DNS resolution (nslookup)

```
$ nslookup networkwalks.com
```

- Resolver: 192.168.10.1 (local gateway). Non-authoritative answer: **192.232.216.135**.

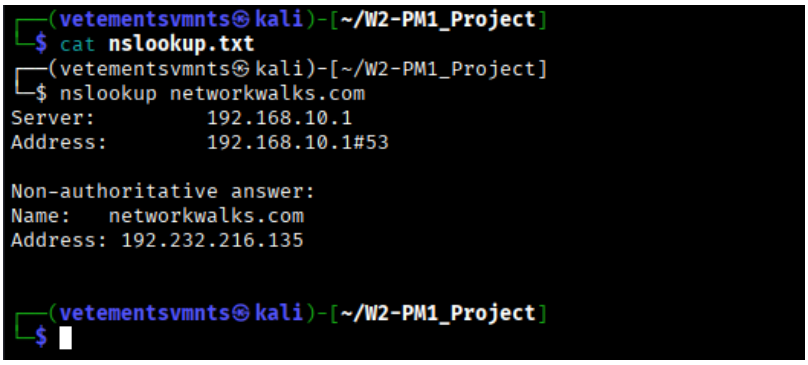


Figure 4: nslookup resolving networkwalks.com

Assessment: the origin IP is exposed (no CDN masks it). An adversary can target it directly, look up co-hosted sites on the same address and attempt to bypass any edge protection.

5.3 DNS enumeration (dnsrecon)

```
$ dnsrecon -d networkwalks.com
```

Record	Value	Comment
SOA	ns6135.hostgator.com 50.87.144.87	Primary authoritative server

Record	Value	Comment
NS	ns6136.hostgator.com 192.232.216.131; ns6135.hostgator.com 50.87.144.87	Both answer the BIND version query
Bind version	"9.16.23-RH" on both name servers	Version disclosure (NW-04)
MX	mail.networkwalks.com 192.232.216.135	Mail on the same host as the web server
A	networkwalks.com 192.232.216.135	Matches nslookup
TXT	google-site-verification=rr04eRmqHoWY3XemnizDNVK4q75X-Ij-mjgEeg-UsYI	Google ownership token
TXT (SPF)	v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all	Soft-fail and permissive (NW-02)
SRV x8	_autodiscover._tcp -> cpanelemaildiscovery.cpanel.net, 184.94.203.x/204.x, port 443	Confirms cPanel mail platform
DNSSEC	No answer for DNSSEC query	Zone unsigned (NW-05)

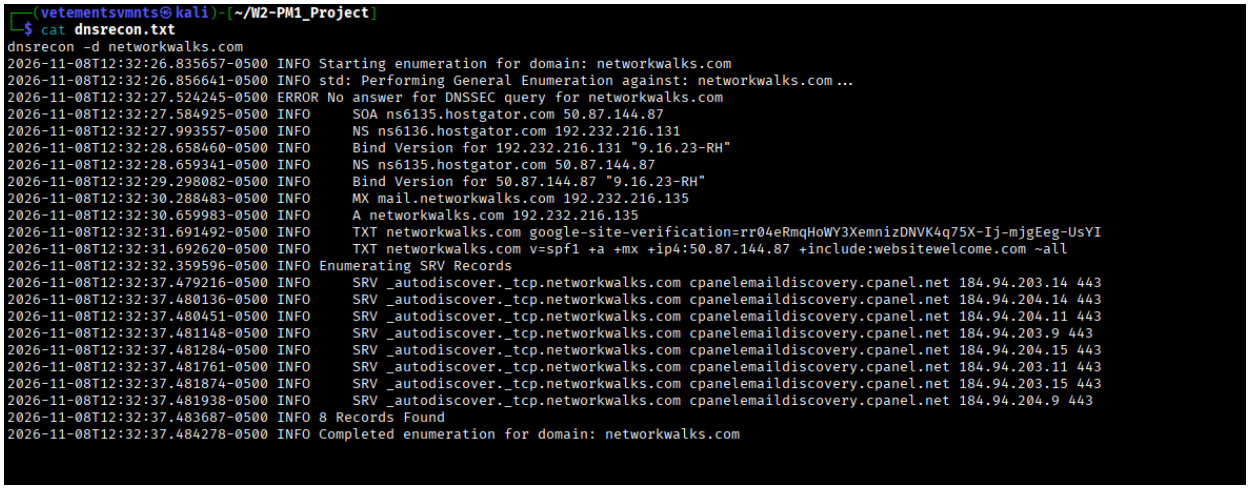


Figure 5: dnsrecon output for networkwalks.com (8 records found)

Assessment: the DNS footprint reveals the mail and hosting platform and the e-mail authentication policy. Attackers use the SPF record to judge spoofability and the SRV records to target cPanel and mail endpoints.

5.4 Web technology fingerprinting (whatweb)

```
$ whatweb --open-timeout 60 --read-timeout 120 networkwalks.com
```

- `http://networkwalks.com` returns **301 Moved Permanently** to HTTPS; `https://networkwalks.com/` returns **200 OK**.
- Stack: Apache, WordPress 7.1.4, WordPress Download Manager 3.3.75, jQuery 3.7.1, HTML5, Google Tag Manager, Open Graph; title `Networkwalks Academy`.
- Leaks: IP `192.232.216.135`, e-mail `info@networkwalks.com`, cookie `__wpdm_client` (HttpOnly), headers `x-redirect-by`, `x-nginx-cache`, `x-endurance-cache-level`.
- `Bootstrap[7.1.4]` mirrors the WordPress version and is likely a false positive.

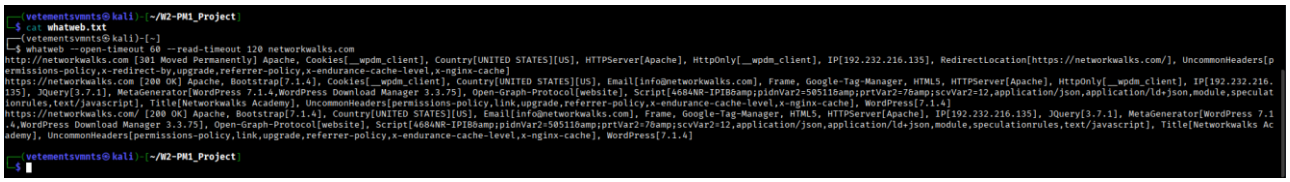


Figure 6: WhatWeb fingerprint output (full-resolution screenshot retained with the evidence files)

Assessment: exact component versions give an adversary a precise lookup key for public exploit and advisory databases; this is the main enabler for the next phase (NW-03).

5.5 HTTP response headers (curl -I)

```
$ curl -I https://networkwalks.com
```

Header	Observed value	Assessment
Status	HTTP/2 200	HTTPS served over HTTP/2
server	Apache	No version in banner (good)
link	wp-json REST API, shortlink	REST API discoverable (NW-06)
set-cookie	__wpdm_client=...; path=/; domain=networkwalks.com; secure; HttpOnly	Good flags; no SameSite (NW-01)
referrer-policy	no-referrer-when-downgrade	Weaker than recommended (NW-01)
permissions-policy	private-state-token-redemption / issuance allow-lists	Present
x-nginx-cache / x-endurance-cache-level	WordPress / 0	Reveals caching stack (NW-03)
Strict-Transport-Security	Not present	Missing (NW-01)
Content-Security-Policy	Not present	Missing (NW-01)
X-Frame-Options / X-Content-Type-Options	Not present	Missing (NW-01)
date	Fri, 06 Nov 2026 06:57:12 GMT	Test timestamp



Figure 7: curl -I response headers for https://networkwalks.com

Assessment: the headers expose the REST API entry point and caching stack without loading the page, and show which browser protections are absent.

5.6 WAF detection (wafw00f)

```
$ wafw00f networkwalks.com
```

- wafw00f v2.4.2 reports: **the site is behind ModSecurity (SpiderLabs) WAF**, using 2 requests.

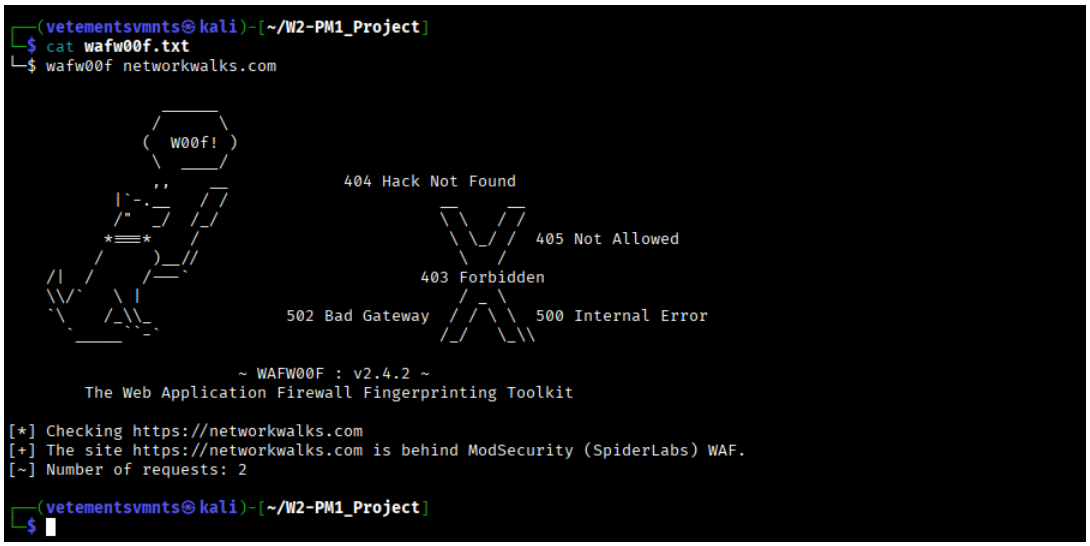


Figure 8: wafw00f detecting ModSecurity (SpiderLabs)

Assessment: a WAF is a positive control. Its presence tells an attacker to expect blocking and logging, and tells a tester to tune later scans (rate, user-agent, payloads) and to confirm WAF rules are not the only line of defence.

5.7 Tester network discovery (Zenmap / nmap -sn)

```
$ nmap -sn 192.168.10.0/24    (Zenmap profile: Ping scan)
```

This scan targets the tester's own lab LAN to document the assessment environment; it is **not** a scan of the external target. Nmap reported 3 hosts up out of 256 addresses in 2.56 seconds (host discovery only, no port scan).

Host	IP address	MAC / vendor	Role
(gateway)	192.168.10.1	80:AF:CA:2D:11:94 (Shenzhen Cudy Technology)	Router / DNS resolver
Lenovo.lan	192.168.10.153	44:A3:BB:69:1B:94 (Intel Corporation)	Workstation (presumed VM host)
kali.lan	192.168.10.23	Local host (scanner)	Kali VM, test platform

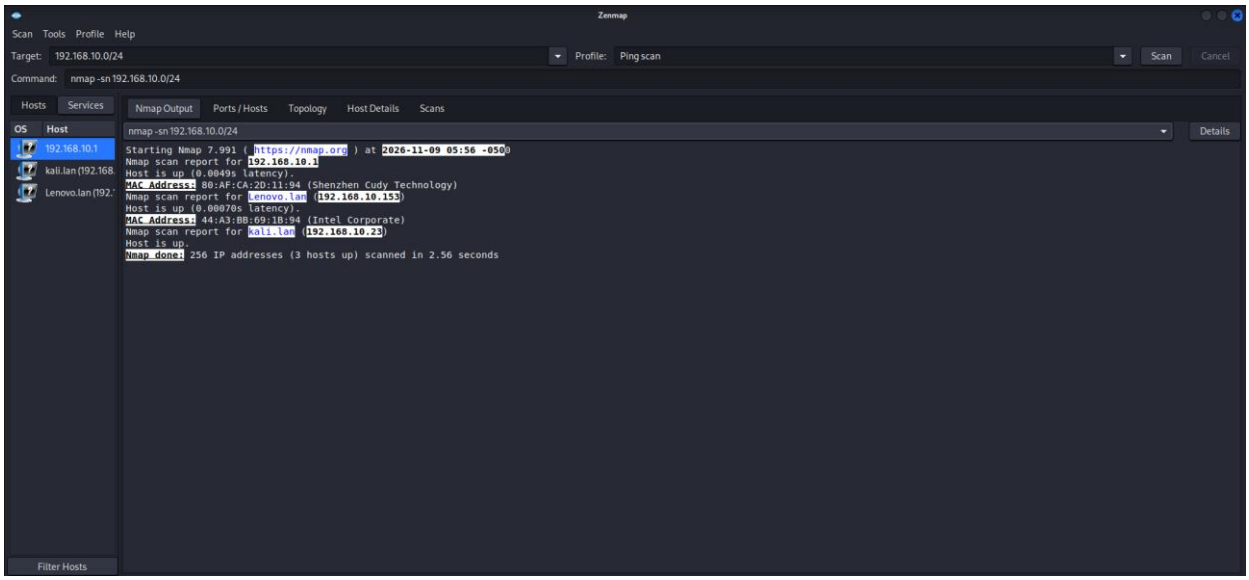


Figure 9: Zenmap ping-scan output for 192.168.10.0/24

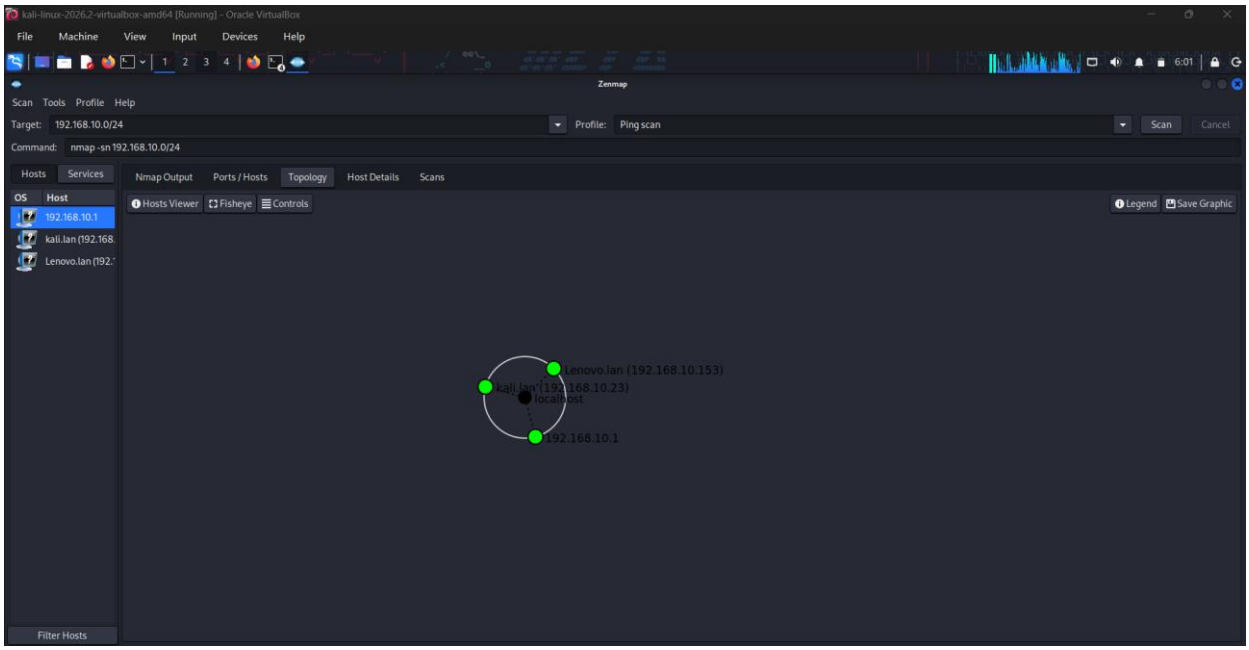


Figure 10: Zenmap topology view of the discovered hosts (Kali VM in VirtualBox)

Assessment: the lab network is small and flat. The scan confirms the gateway is also the resolver used for the DNS tests, which is why those answers are non-authoritative. Keep the testing VM isolated from production devices on the same LAN.

6. Detailed Findings

NW-01 - Missing HTTP security response headers and weak cookie/referrer settings

Severity	**Low**
Affected asset	https://networkwalks.com (192.232.216.135)
Evidence	`curl -I https://networkwalks.com` (Figure 7). The response contains permissions-policy, referrer-policy: no-referrer-when-downgrade and a Set-Cookie for `__wpdm_client` (Secure; HttpOnly) but no Strict-Transport-Security, Content-Security-Policy, X-Frame-Options (or frame-ancestors) or X-Content-Type-Options header, and no SameSite attribute on the cookie.
Description	Browser-side protections that cost little to deploy are not advertised by the application. Observation is limited to a single HEAD request against the home page, so headers set only on other paths were not assessed.
Impact	Weaker defence in depth against clickjacking, MIME-sniffing, TLS-downgrade on first visit and cross-site request/cookie abuse. These controls do not fix a vulnerability on their own but reduce the impact of any XSS or framing issue found later.
Recommendation	• Add `Strict-Transport-Security: max-age=31536000; includeSubDomains` after confirming all subdomains support HTTPS. • Introduce a Content-Security-Policy (start in Report-Only mode), plus `X-Content-Type-Options: nosniff` and `frame-ancestors` / `X-Frame-Options`. • Tighten Referrer-Policy to `strict-origin-when-cross-origin` and set `SameSite=Lax` on application cookies.
References	OWASP Secure Headers Project; OWASP WSTG-CONF-07; CWE-693; CWE-1021

NW-02 - E-mail authentication posture: permissive SPF, DMARC and DKIM unverified

Severity	**Low**
Affected asset	networkwalks.com DNS (TXT) and mail.networkwalks.com (192.232.216.135)
Evidence	dnsrecon TXT record: `v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all` (Figure 5). `_dmarc` and DKIM selector records are not returned by a standard dnsrecon run and were not queried.
Description	The SPF policy ends in soft-fail (`~all`), explicitly authorises every A/MX host plus a shared-hosting IP (50.87.144.87, also a name-server address) and includes a shared-hosting provider domain, which widens the set of senders that can pass SPF. Without an enforced DMARC policy, receivers are not told to reject spoofed mail.
Impact	Increased likelihood of domain spoofing and convincing phishing that appears to originate from the Networkwalks domain, targeting students, customers or staff. Severity may rise to Medium if DMARC is confirmed absent.
Recommendation	• Verify `_dmarc.networkwalks.com` and DKIM selectors; publish DMARC starting at `p=none` with `rua` reporting, then move to `quarantine` and `reject`. • Enable DKIM signing in cPanel and review all legitimate sending sources. • Tighten SPF to `-all` once sources are confirmed; remove `+a`/`+mx` and the shared IP if not required, staying within the 10-lookup limit.
References	RFC 7208 (SPF); RFC 6376 (DKIM); RFC 7489 (DMARC); MITRE ATT&CK T1566

NW-03 - Software and version disclosure on the web tier

Severity	**Low**
Affected asset	https://networkwalks.com (192.232.216.135)
Evidence	WhatWeb (Figure 6): MetaGenerator `WordPress 7.1.4, WordPress Download Manager 3.3.75`, Apache, jQuery 3.7.1, Google Tag Manager, e-mail info@networkwalks.com. Headers (Figure 7): `x-nginx-cache`, `x-endurance-cache-level`, `x-redirect-by`.
Description	The generator meta tag and caching headers disclose the CMS, a plugin, its exact versions and the hosting/caching stack. WhatWeb also reports `Bootstrap[7.1.4]`, which duplicates the WordPress version string and is most likely a fingerprinting false positive; it should not be relied on.
Impact	Lets an adversary match exact versions to public advisories without touching the application. Whether the disclosed versions are vulnerable was not determined in this phase; disclosure itself is a Low-severity hardening issue.
Recommendation	• Keep WordPress core, plugins and themes on the latest supported release with automatic security updates; check the disclosed versions against vendor and NVD/WPScan advisories. • Remove the generator tag (`remove_action('wp_head','wp_generator')`) and strip version query strings where practical. • Where the host allows, suppress non-essential headers (`ServerTokens Prod`, `Header unset`) for cache and redirect markers.
References	OWASP WSTG-INFO-02, INFO-08; CWE-200; MITRE ATT&CK T1592.002

NW-04 - DNS server software version disclosure (BIND 9.16.23-RH)

Severity	**Low**
Affected asset	ns6135.hostgator.com (50.87.144.87), ns6136.hostgator.com (192.232.216.131)
Evidence	dnsrecon (Figure 5): `Bind Version for 192.232.216.131 "9.16.23-RH"` and `Bind Version for 50.87.144.87 "9.16.23-RH"`.
Description	Both authoritative servers answer the CHAOS-class version query with their BIND build string. The `-RH` suffix indicates a Red Hat packaged build, which usually carries back-ported fixes, so the string alone does not prove a vulnerability. The upstream 9.16 branch is, however, a legacy release line.
Impact	Small information-leak that helps an adversary profile the DNS platform. The servers are operated by the hosting provider, so remediation is outside the customer's direct control.
Recommendation	• Raise with the hosting provider and request `version` and `hostname` banners be hidden or set to a neutral string. • If the provider will not change this, consider moving DNS hosting to a provider that supports DNSSEC and does not expose software versions.
References	CWE-200; MITRE ATT&CK T1590.002

NW-05 - DNSSEC not deployed

Severity	Informational
Affected asset	networkwalks.com (registry and registrar record; dnsrecon)
Evidence	WHOIS: `DNSSEC: unsigned` (Figures 2 and 3). dnsrecon: `No answer for DNSSEC query for networkwalks.com` (Figure 5).
Description	The zone is not signed and no DS record is published at the registry.
Impact	Resolvers cannot cryptographically validate answers, leaving the domain open in principle to cache-poisoning or spoofed DNS responses. This is an industry-wide gap and exploitation is non-trivial.
Recommendation	• Enable DNSSEC at a DNS provider that supports it and publish the DS record at the registrar (GoDaddy).
References	RFC 4033-4035; CWE-345

NW-06 - WordPress REST API advertised in HTTP Link header

Severity	Informational
Affected asset	https://networkwalks.com/wp-json/
Evidence	`curl -I` (Figure 7): `link: <https://networkwalks.com/wp-json/>; rel="https://api.w.org/"` and `<.../wp-json/wp/v2/pages/53>; rel="alternate"`.
Description	The REST API entry point is discoverable from the headers alone. By default the API can expose published content and, on some configurations, a list of user accounts at `/wp-json/wp/v2/users`. This was not tested in this phase.
Impact	Potential account-name enumeration that would support credential-guessing or phishing. Impact depends on configuration and on the strength of the login controls.
Recommendation	• In the next phase, test `/wp-json/wp/v2/users` and `?author=N` enumeration under authorisation. • Restrict user enumeration (security plugin or `rest_endpoints` filter), enforce MFA and rate-limiting on `wp-login.php`.
References	OWASP WSTG-IDNT-04; WSTG-INFO-06; CWE-203

NW-07 - Name-server inconsistency between registry and registrar records

Severity	Informational
Affected asset	networkwalks.com delegation
Evidence	Registry record (Figure 2) lists NS6135/NS6136.HOSTGATOR.COM. The registrar WHOIS record (Figure 3) additionally lists NS29.DOMAINCONTROL.COM and NS30.DOMAINCONTROL.COM.
Description	The registrar view carries two extra GoDaddy name servers that are not present in the registry delegation. This can be a harmless provisioning default, a stale record from an earlier DNS host, or an unsynchronised change.
Impact	Stale or unsynchronised delegation can cause inconsistent resolution and, in worst cases, create a take-over opportunity if a listed name server no longer serves the zone.
Recommendation	• Reconcile the name-server set at the registrar and confirm each listed server is authoritative for the zone; remove any that are not.
References	OWASP WSTG-CONF-10 (subdomain/DNS takeover); MITRE ATT&CK T1596.002

NW-08 - Consolidated shared-hosting footprint (web, mail and cPanel services)

Severity	Informational
Affected asset	192.232.216.135; 50.87.144.87; 184.94.203.x / 184.94.204.x
Evidence	nslookup and dnsrecon (Figures 4 and 5): A and MX records both resolve to 192.232.216.135; SPF includes `websitewelcome.com`; eight `_autodiscover._tcp` SRV records point to `cpanelemaildiscovery.cpanel.net`.
Description	Web, e-mail and control-panel services appear to share a HostGator/cPanel platform. The SRV records confirm cPanel-based mail auto-configuration.
Impact	A compromise on one service, or a noisy neighbour on shared infrastructure, can affect web and mail together. cPanel and webmail endpoints are well-known targets for credential attacks.
Recommendation	• Enforce MFA on cPanel/webmail and restrict control-panel access by IP where the provider allows. • Review whether mail should be moved to a dedicated provider and maintain off-host backups and monitoring.
References	OWASP WSTG-INFO-10; MITRE ATT&CK T1590

NW-09 - Public contact address exposed on the website

Severity	Informational
Affected asset	https://networkwalks.com
Evidence	WhatWeb (Figure 6): `Email[info@networkwalks.com]`.
Description	A role-based mailbox is published on the home page and harvested automatically by fingerprinting tools. WHOIS privacy is in place, so no personal registrant data was exposed.
Impact	Low: the address is a deliberate public contact point but is a likely phishing and spam target.
Recommendation	• Keep inbound filtering and DMARC enforcement strong (see NW-02) and consider a contact form instead of a plain address.
References	OWASP WSTG-INFO-05; CWE-200

7. Remediation Roadmap

Priority	Action	Findings	Effort	Target
P1	Deploy security headers and SameSite cookies; verify with a header scanner	NW-01	Low	30 days
P1	Publish and enforce DMARC, enable DKIM, tighten SPF	NW-02	Low-Med	30 days
P1	Update WordPress core and plugins; remove generator tag; check versions against advisories	NW-03	Low	30 days
P2	Test and restrict REST user enumeration; MFA and rate-limit on login	NW-06	Medium	60 days
P2	Reconcile name-server set at the registrar	NW-07	Low	60 days
P2	Ask provider to hide BIND version banner or change DNS host	NW-04	Provider	90 days
P3	Enable DNSSEC with a supporting DNS provider and publish DS	NW-05	Medium	90 days
P3	Enforce MFA on cPanel and webmail; review shared-hosting and mail architecture	NW-08	Medium	90 days
P3	Use a role mailbox with filtering or a contact form; enable domain auto-renew	NW-09	Low	90 days

8. Recommended Next Phase

The following steps complete the VAPT lifecycle. Each is active testing and **must be covered by written authorisation and an agreed scope** before it starts.

Activity	Objective	Suggested tooling
Service and port discovery	Identify open ports and exposed services (including cPanel/webmail) on 192.232.216.135	nmap -sV, rate-limited
TLS configuration review	Protocols, ciphers, certificate chain and HSTS posture	testssl.sh, sslyze
WordPress enumeration	Plugins, themes, versions and user enumeration (NW-03, NW-06)	WPScan (non-intrusive)
Vulnerability correlation	Match WordPress 7.1.4, WPDM 3.3.75 and BIND 9.16.23-RH to advisories and validate safely	NVD, WPScan DB, vendor advisories
E-mail security validation	Confirm DMARC/DKIM and spoofability	dig, mail-tester tools
Sub-domain and certificate transparency review	Discover additional hosts and forgotten assets	Passive sources, amass (passive)
Scoped search-engine review	Look for accidentally indexed files or admin pages on the organisation's own domain only	`site:networkwalks.com` queries
Content discovery and WAF-aware testing	Hidden paths and input handling, tuned to the ModSecurity rules	Low-rate fuzzing, Burp Suite

Scope exclusions

The Week 2 Project Module 2 brief (Google Hacking Database footprinting) was supplied with this engagement. It contains only the task sheet and no results, and its first task asks for live exposed third-party security cameras to be located and opened. Accessing devices owned by unrelated parties is outside an authorised assessment of networkwalks.com, so that module is **not part of this report** and no camera or credential data is recorded. Google-dork review is covered here only as a scoped activity against the organisation's own domain (see table above).

Appendix A - Command and Evidence Log

Tool	Command	Evidence timestamp	Saved file / figure
whois	whois networkwalks.com	Registry DB update 2026-11-05 07:03Z	Task1_whois.txt; Figs 2-3
whatweb	whatweb --open-timeout 60 --read-timeout 120 networkwalks.com	Not logged	whatweb.txt; Fig 6
nslookup	nslookup networkwalks.com	Not logged	nslookup.txt; Fig 4
curl	curl -I https://networkwalks.com	Fri 06 Nov 2026 06:57:12 GMT	curl.txt; Fig 7
wafw00f	wafw00f networkwalks.com (v2.4.2)	Not logged	wafw00f.txt; Fig 8
dnsrecon	dnsrecon -d networkwalks.com	2026-11-08 12:32 -0500	dnsrecon.txt; Fig 5
Zenmap	nmap -sn 192.168.10.0/24 (Nmap 7.991 as displayed)	2026-11-09 05:56 -0500	Figs 9-10

Working directory: `~/W2-PM1_Project` on the Kali VM (kali-linux-2026.2, VirtualBox). Original screenshots and text outputs should be archived with this report as the evidence set.

Appendix B - Glossary

Term	Meaning
VAPT	Vulnerability Assessment and Penetration Testing: finding weaknesses and, with authorisation, validating them by controlled attack.
Footprinting	Collecting information about a target before testing; the first stage of an assessment.
WAF	Web Application Firewall that filters HTTP traffic to block common web attacks.
SPF / DKIM / DMARC	DNS-based e-mail authentication controls that limit spoofing of a domain.
DNSSEC	Signing of DNS data so resolvers can verify answers are authentic.
SRV record	DNS record that advertises the location of a service, here cPanel mail autodiscovery.
CHAOS version query	DNS query that makes some servers reveal their software version.